

Batch 1: ISO 27001 & ISO 27002 – 50 Questions

1. Which ISO standard specifies ISMS requirements?
 - ☐ a) ISO 31000
 - ☒ b) ISO 27001 ✓
 - ☐ c) ISO 22301
 - ☐ d) ISO 9001
2. Which ISO standard provides security control guidelines?
 - ☒ a) ISO 27002 ✓
 - ☐ b) ISO 27001
 - ☐ c) ISO 31000
 - ☐ d) ISO 22301
3. Clause 4 of ISO 27001 covers:
 - ☒ a) Context of the organization ✓
 - ☐ b) Leadership
 - ☐ c) Planning
 - ☐ d) Support
4. Clause 5 of ISO 27001 focuses on:
 - ☒ a) Leadership & commitment ✓
 - ☐ b) Risk assessment
 - ☐ c) Control objectives
 - ☐ d) Improvement
5. Clause 6 of ISO 27001 covers:
 - ☒ a) Planning ✓
 - ☐ b) Support
 - ☐ c) Operation
 - ☐ d) Performance evaluation
6. Clause 7 of ISO 27001 refers to:
 - ☒ a) Support ✓
 - ☐ b) Operation
 - ☐ c) Performance evaluation
 - ☐ d) Improvement
7. Clause 8 of ISO 27001 is about:
 - ☒ a) Operation ✓
 - ☐ b) Support
 - ☐ c) Performance evaluation
 - ☐ d) Leadership
8. Clause 9 of ISO 27001 relates to:
 - ☒ a) Performance evaluation ✓
 - ☐ b) Operation
 - ☐ c) Support
 - ☐ d) Leadership
9. Clause 10 of ISO 27001 covers:
 - ☒ a) Improvement ✓
 - ☐ b) Risk management

- c) Leadership
 - d) Operation
- 10. ISO 27001 Annex A controls are grouped into how many domains?
 - a) 12
 - b) 14 ✓
 - c) 16
 - d) 10
- 11. Which control domain covers access control?
 - a) A.9 ✓
 - b) A.7
 - c) A.5
 - d) A.11
- 12. Which control domain focuses on human resource security?
 - a) A.7 ✓
 - b) A.6
 - c) A.8
 - d) A.9
- 13. Which control domain deals with cryptography?
 - a) A.10 ✓
 - b) A.11
 - c) A.12
 - d) A.13
- 14. Which control domain covers physical security?
 - a) A.11 ✓
 - b) A.10
 - c) A.12
 - d) A.13
- 15. Which control domain addresses operations security?
 - a) A.12 ✓
 - b) A.11
 - c) A.10
 - d) A.14
- 16. Which domain focuses on communications security?
 - a) A.13 ✓
 - b) A.14
 - c) A.12
 - d) A.15
- 17. Which domain deals with system acquisition, development, and maintenance?
 - a) A.14 ✓
 - b) A.13
 - c) A.12
 - d) A.15
- 18. Which domain focuses on supplier relationships?
 - a) A.15 ✓
 - b) A.14

- c) A.13
 - d) A.16
- 19. Which domain covers information security incident management?
 - a) A.16 ✓
 - b) A.15
 - c) A.14
 - d) A.13
- 20. Which domain deals with information security aspects of business continuity?
 - a) A.17 ✓
 - b) A.16
 - c) A.15
 - d) A.18
- 21. Which domain addresses compliance with legal and regulatory requirements?
 - a) A.18 ✓
 - b) A.17
 - c) A.16
 - d) A.15
- 22. Risk assessment in ISO 27001 is required to be:
 - a) One-time
 - b) Periodic and on changes ✓
 - c) Only before audits
 - d) Only when incidents occur
- 23. ISMS scope should include:
 - a) Only IT assets
 - b) All organizational assets within the defined boundary ✓
 - c) Only confidential data
 - d) Only cloud assets
- 24. Management review frequency as per ISO 27001 is:
 - a) Monthly
 - b) Annually
 - c) Periodically ✓
 - d) Never
- 25. Statement “Information security objectives must be measurable” aligns with which clause?
 - a) 6.2 ✓
 - b) 5.1
 - c) 8.1
 - d) 9.1
- 26. Corrective actions should be taken when:
 - a) Nonconformities are identified ✓
 - b) Risk is low
 - c) Audit is pending
 - d) Control is effective
- 27. Preventive actions are:

- a) Required by ISO 27001 ✗ (ISO 27001 uses risk-based approach, preventive is implicit)
 - b) Mandatory
 - c) Optional
 - d) Explicitly required
28. Information security policy should be:
- a) Only for IT
 - b) Approved by top management ✓
 - c) Drafted by auditors
 - d) Only for external partners
29. Control A.8 covers:
- a) Asset management ✓
 - b) Human resources
 - c) Access control
 - d) Communications
30. ISO 27001 requires documented information for:
- a) Only policies
 - b) All processes and procedures that affect ISMS ✓
 - c) Only risk registers
 - d) Only controls
31. Statement: “All employees must receive security awareness training” relates to:
- a) A.7.2 ✓
 - b) A.9.1
 - c) A.12.3
 - d) A.13.2
32. Correct definition of control in ISO 27001:
- a) Anything implemented to manage risk ✓
 - b) Only technical tool
 - c) Only policy
 - d) Only preventive measure
33. Asset classification should be based on:
- a) Value, sensitivity, criticality ✓
 - b) Department size
 - c) Audit frequency
 - d) ISO 31000
34. Access rights should follow the principle of:
- a) Maximum privilege
 - b) Need-to-know ✓
 - c) Supervisor discretion
 - d) Annual approval
35. Information transfer policies are part of which domain?
- a) A.13 ✓
 - b) A.12
 - c) A.11
 - d) A.10

36. Mobile device management policies belong to:
- a) A.6
 - b) A.6.2 & A.13 ✓
 - c) A.9 only
 - d) A.18
37. ISMS documentation must include:
- a) Only policies
 - b) Procedures, scope, objectives, risk assessment ✓
 - c) Only audit reports
 - d) Only risk register
38. Supplier security requirements are defined in:
- a) A.15 ✓
 - b) A.14
 - c) A.16
 - d) A.13
39. Security incident reporting is required by which control?
- a) A.16.1 ✓
 - b) A.15.1
 - c) A.14.2
 - d) A.12.3
40. Business continuity planning control in ISO 27001 Annex A is:
- a) A.17 ✓
 - b) A.16
 - c) A.15
 - d) A.18
41. Management is responsible for ensuring:
- a) Funding only
 - b) ISMS establishment, implementation, maintenance ✓
 - c) Audit only
 - d) None of the above
42. Internal audit should assess:
- a) Compliance with ISO 27001 ✓
 - b) Only risk registers
 - c) Only IT operations
 - d) Only external policies
43. Nonconformities must be:
- a) Ignored
 - b) Corrected and documented ✓
 - c) Delegated
 - d) Optional
44. Continual improvement in ISO 27001 involves:
- a) PDCA cycle ✓
 - b) Risk avoidance only
 - c) Asset classification
 - d) Only internal audits

45. Information security roles & responsibilities are covered in:
- a) Clause 5 ✓
 - b) Clause 4
 - c) Clause 6
 - d) Clause 7
46. Risk acceptance requires:
- a) Documentation and management approval ✓
 - b) Immediate mitigation
 - c) Ignoring risk
 - d) Only audit review
47. Physical and environmental security controls are in:
- a) A.11 ✓
 - b) A.10
 - c) A.12
 - d) A.13
48. Logging and monitoring is part of:
- a) A.12.4 ✓
 - b) A.13.2
 - c) A.9.2
 - d) A.8.3
49. Cryptographic control selection should consider:
- a) Business requirements, legal obligations, risk assessment ✓
 - b) Employee preference
 - c) Audit frequency
 - d) None
50. Information security in project management is part of:
- a) A.14.2 ✓
 - b) A.13.1
 - c) A.12.3
 - d) A.11.1

Batch 2: Risk Management – 50 Questions

1. ISO 31000 focuses on:
- a) Quality management
 - b) Risk management principles ✓
 - c) Information security controls
 - d) Business continuity
2. Risk is defined as:
- a) $\text{Threat} \times \text{Vulnerability} \times \text{Impact}$ ✓
 - b) $\text{Likelihood} \times \text{Cost}$
 - c) $\text{Asset} \times \text{Threat}$
 - d) $\text{Vulnerability} \times \text{Asset}$
3. Another common formula for risk is:
- a) $\text{Risk} = \text{Likelihood} \times \text{Impact}$ ✓

- b) Risk = SLE × ARO
 - c) Risk = RTO × RPO
 - d) Risk = Residual Risk × Control
- 4. Inherent risk refers to:
 - a) Risk after controls
 - b) Risk before controls ✓
 - c) Risk ignored
 - d) Residual risk
- 5. Residual risk is:
 - a) Risk before controls
 - b) Risk remaining after controls ✓
 - c) Risk transferred to insurers
 - d) Risk avoided
- 6. ALE stands for:
 - a) Annual Loss Estimate
 - b) Annualized Loss Expectancy ✓
 - c) Asset Loss Evaluation
 - d) Audit Loss Estimate
- 7. SLE formula:
 - a) SLE = Asset Value × Exposure Factor ✓
 - b) SLE = Likelihood × Impact
 - c) SLE = ALE × ARO
 - d) SLE = Risk × Control
- 8. ALE formula:
 - a) ALE = SLE × ARO ✓
 - b) ALE = Likelihood × Impact
 - c) ALE = Residual Risk × Controls
 - d) ALE = RTO × RPO
- 9. ARO stands for:
 - a) Annual Risk Occurrence
 - b) Annual Rate of Occurrence ✓
 - c) Asset Risk Option
 - d) Assessment Rate Outcome
- 10. Exposure Factor (EF) is:
 - a) Percentage of asset loss in a single incident ✓
 - b) Likelihood of occurrence
 - c) Control effectiveness
 - d) Risk tolerance
- 11. Risk appetite is:
 - a) Risk organization is willing to accept ✓
 - b) Maximum risk tolerated without controls
 - c) Residual risk
 - d) Likelihood × Impact
- 12. Risk tolerance refers to:
 - a) Acceptable deviation from risk appetite ✓

- b) Risk after mitigation
 - c) Inherent risk
 - d) Asset loss
13. Risk avoidance strategy means:
- a) Stop activity causing risk ✓
 - b) Reduce risk
 - c) Transfer risk
 - d) Accept risk
14. Risk mitigation strategy:
- a) Reduce likelihood or impact ✓
 - b) Ignore risk
 - c) Transfer risk
 - d) Stop activity
15. Risk transfer example:
- a) Insurance ✓
 - b) Ignoring risk
 - c) Accepting risk
 - d) Shutting down system
16. Risk acceptance is:
- a) Documenting residual risk ✓
 - b) Ignoring risk
 - c) Transferring risk
 - d) Avoiding risk
17. Key risk assessment steps include:
- a) Identify, analyze, evaluate ✓
 - b) Transfer, avoid, accept
 - c) Audit only
 - d) Monitor only
18. Likelihood in risk assessment is:
- a) Probability of risk occurring ✓
 - b) Impact severity
 - c) Control effectiveness
 - d) Residual risk
19. Impact refers to:
- a) Severity of consequences if risk occurs ✓
 - b) Likelihood of occurrence
 - c) Control efficiency
 - d) Asset value
20. Risk formula for residual risk is:
- a) Residual risk = Inherent risk – Control effectiveness ✓
 - b) Residual risk = ALE – SLE
 - c) Residual risk = Likelihood × Impact
 - d) Residual risk = RTO – RPO
21. ISO 31000 emphasizes:
- a) Risk as a process ✓

- b) Risk as a one-time assessment
 - c) Risk only for IT
 - d) Risk for audit only
22. Risk treatment plan should include:
- a) Action, owner, timeline ✓
 - b) Risk register only
 - c) Audit report only
 - d) Asset value only
23. Which risk strategy is least active?
- a) Mitigate
 - b) Accept ✓
 - c) Transfer
 - d) Avoid
24. Risk register should include:
- a) Identified risks, likelihood, impact, treatment ✓
 - b) Only high risks
 - c) Only residual risks
 - d) Only control measures
25. ISO 31000 risk principles include:
- a) Integrated, structured, customized, inclusive ✓
 - b) Avoid, transfer, accept, mitigate
 - c) SLE, ARO, ALE
 - d) Audit, control, monitor
26. Risk identification techniques include:
- a) Brainstorming, checklists, interviews ✓
 - b) ALE calculation only
 - c) RTO and RPO
 - d) PDCA
27. Which is qualitative risk assessment?
- a) Using Likert scale, ratings ✓
 - b) Using ALE only
 - c) Using RTO
 - d) Using $SLE \times ARO$
28. Quantitative risk assessment relies on:
- a) Numbers, ALE, probabilities ✓
 - b) Checklist only
 - c) Interviews only
 - d) Policies
29. Which is a residual risk example?
- a) Risk remaining after fire suppression installed ✓
 - b) Total risk before control
 - c) Risk ignored
 - d) Risk avoided
30. Scenario: Asset value = \$50,000, EF = 0.6, ARO = 2/year. Calculate ALE.
- a) \$60,000 ✓

- b) \$50,000
- c) \$100,000
- d) \$30,000
- **Solution:** $SLE = 50,000 \times 0.6 = 30,000$; $ALE = 30,000 \times 2 = 60,000$

31. Risk assessment frequency should be:

- a) Periodic and on changes ✓
- b) Once only
- c) Only during audits
- d) Only when incidents occur

32. Control effectiveness formula is:

- a) $\% \text{ risk reduction} = (\text{Inherent} - \text{Residual}) / \text{Inherent} \times 100$ ✓
- b) $ALE \times ARO$
- c) $\text{Risk} \times \text{Impact}$
- d) $SLE \times EF$

33. Key components of risk management framework:

- a) Context, assessment, treatment, monitoring ✓
- b) Audit only
- c) BCP only
- d) Policies only

34. Which risk treatment is preferred for high-impact risk?

- a) Avoid or mitigate ✓
- b) Accept
- c) Transfer only
- d) Ignore

35. Risk communication is:

- a) Sharing risk info with stakeholders ✓
- b) Only documenting risk
- c) Only auditing
- d) Only calculating ALE

36. Key output of risk assessment is:

- a) Risk register ✓
- b) Asset inventory
- c) Internal audit report
- d) Policies

37. Residual risk must be:

- a) Monitored regularly ✓
- b) Ignored
- c) Only documented once
- d) Always avoided

38. Risk appetite is defined by:

- a) Top management ✓
- b) IT department only
- c) Auditors
- d) Risk officers only

39. Risk owner is responsible for:

- a) Implementing controls and monitoring ✓
 - b) Calculating ALE only
 - c) Audit only
 - d) Asset classification only
- 40. Risk likelihood scale is typically:
 - a) 1–5 or 1–10 ✓
 - b) 0–100 only
 - c) True/False
 - d) Asset value
- 41. Impact scale is:
 - a) Low, Medium, High ✓
 - b) Only numbers
 - c) True/False
 - d) None
- 42. When to perform risk reassessment?
 - a) When significant changes occur ✓
 - b) Never
 - c) Only during audits
 - d) Only annually
- 43. Risk documentation is mandatory in:
 - a) ISO 31000 ✓
 - b) Only ISO 27001
 - c) Only audits
 - d) Optional
- 44. Risk treatment plan must include:
 - a) Who, what, when, how ✓
 - b) Only controls
 - c) Only residual risk
 - d) Only likelihood
- 45. Control selection must be based on:
 - a) Cost, effectiveness, risk reduction ✓
 - b) Preference
 - c) Audit findings only
 - d) Only regulations
- 46. Risk monitoring includes:
 - a) Tracking residual risk and control performance ✓
 - b) Documenting SLE only
 - c) Only audits
 - d) Ignoring low risks
- 47. ISO 31000 risk principles emphasize:
 - a) Integration into organizational processes ✓
 - b) One-time assessment
 - c) Only IT risks
 - d) Only external audits
- 48. Risk evaluation compares:

- a) Risk level against risk criteria ✓
 - b) ALE vs RTO
 - c) SLE vs EF
 - d) RPO vs impact
49. A high-probability, low-impact risk may be:
- a) Accepted ✓
 - b) Avoided
 - c) Mitigated
 - d) Transferred
50. ISO 31000 recommends risk management to be:
- a) Iterative, continuous ✓
 - b) One-time
 - c) Reactive only
 - d) Optional

Batch 3: Business Continuity – 30 Questions

1. ISO 22301 is the standard for:
 - a) Information security
 - b) Business continuity management ✓
 - c) Risk management
 - d) Quality management
2. Business Continuity Management (BCM) aims to:
 - a) Minimize downtime and maintain critical operations ✓
 - b) Avoid all risks
 - c) Audit IT only
 - d) Only secure assets
3. RTO stands for:
 - a) Recovery Time Objective ✓
 - b) Risk Transfer Option
 - c) Residual Time Optimization
 - d) Recovery Task Order
4. RPO stands for:
 - a) Recovery Point Objective ✓
 - b) Risk Probability Option
 - c) Residual Process Objective
 - d) Recovery Plan Outline
5. RTO defines:
 - a) Maximum acceptable downtime ✓
 - b) Maximum acceptable data loss
 - c) Control effectiveness
 - d) Likelihood of risk
6. RPO defines:
 - a) Maximum acceptable data loss ✓
 - b) Maximum acceptable downtime

- c) Risk reduction factor
 - d) Audit period
- 7. Business Impact Analysis (BIA) identifies:
 - a) Critical processes and their impact on operations ✓
 - b) Only IT systems
 - c) Audit reports
 - d) Only asset inventory
- 8. The main output of BIA is:
 - a) Prioritized recovery plan ✓
 - b) Risk register
 - c) Residual risk
 - d) Security policy
- 9. BCM lifecycle includes:
 - a) Policy, BIA, strategy, plan, test, review ✓
 - b) Audit only
 - c) Risk assessment only
 - d) Asset classification only
- 10. A continuity strategy may include:
 - a) Alternate site, cloud backup, cross-training ✓
 - b) Only insurance
 - c) Only internal audits
 - d) Only risk acceptance
- 11. The main goal of BCM is:
 - a) Ensure critical business functions continue ✓
 - b) Avoid all threats
 - c) Reduce residual risk to zero
 - d) Only secure IT assets
- 12. ISO 22301 requires top management to:
 - a) Ensure BCM integration into organizational processes ✓
 - b) Only approve budget
 - c) Only review audit findings
 - d) Avoid risks
- 13. Testing a BCM plan ensures:
 - a) Effectiveness and readiness ✓
 - b) Only compliance with ISO
 - c) Only audit approval
 - d) Risk avoidance
- 14. Types of BCM tests include:
 - a) Tabletop, simulation, full interruption ✓
 - b) Risk register
 - c) Asset inventory
 - d) Policy review only
- 15. A cold site in BCM refers to:
 - a) Backup facility with no pre-installed equipment ✓
 - b) Fully operational alternate site

- c) Hot data center
 - d) Audit room
16. A hot site refers to:
- a) Fully operational alternate site ready for immediate use ✓✓
 - b) Cold backup
 - c) Only data storage
 - d) Risk assessment office
17. Critical process recovery priority is based on:
- a) BIA results ✓
 - b) Department preference
 - c) Audit frequency
 - d) Asset value only
18. BCM documentation must include:
- a) Plan, roles, responsibilities, procedures ✓
 - b) Only risk register
 - c) Only IT assets
 - d) Only RTO and RPO
19. Communication plan in BCM ensures:
- a) Stakeholders are informed during disruption ✓
 - b) Only management knows
 - c) Only IT staff are aware
 - d) Audit only
20. BCM review frequency should be:
- a) Periodic and after significant changes ✓
 - b) Never
 - c) Only during audits
 - d) Only annually
21. The primary benefit of BCM is:
- a) Business resilience ✓
 - b) Risk elimination
 - c) Zero downtime guarantee
 - d) Audit compliance only
22. ISO 22301 requires performance evaluation of BCM via:
- a) Tests, audits, management review ✓
 - b) Policies only
 - c) Risk register only
 - d) Asset inventory only
23. BCM roles include:
- a) BCM manager, recovery team, process owners ✓
 - b) Only IT manager
 - c) Only top management
 - d) Only auditors
24. Recovery strategies can include:
- a) Manual operations, alternate site, cloud backup ✓
 - b) Only insurance

- c) Only risk acceptance
 - d) None
- 25. RTO and RPO are determined during:
 - a) Business Impact Analysis ✓
 - b) Risk assessment
 - c) Audit review
 - d) Asset classification
- 26. Continuity plans should be:
 - a) Tested and updated regularly ✓
 - b) Static
 - c) Only for IT
 - d) Only during audits
- 27. BCM scope should cover:
 - a) All critical business processes ✓
 - b) Only IT
 - c) Only finance
 - d) Only top management
- 28. Emergency response plan is:
 - a) Immediate actions to protect life and assets ✓
 - b) Long-term recovery
 - c) Audit plan
 - d) Risk register
- 29. Recovery team responsibilities include:
 - a) Executing continuity and recovery procedures ✓
 - b) Only documenting risk
 - c) Only performing audits
 - d) Only monitoring RTO
- 30. ISO 22301 requires continual improvement through:
 - a) Lessons learned from tests, incidents ✓
 - b) One-time implementation
 - c) Only audits
 - d) Only asset updates

Batch 4: Governance & Audit – 30 Questions

1. COBIT stands for:
 - a) Control Objectives for Information and Related Technology ✓
 - b) Cybersecurity Objectives for Business IT
 - c) Compliance Oversight for Business IT
 - d) Control Operations for Best IT
2. COBIT is primarily used for:
 - a) IT governance and management ✓
 - b) Risk management only
 - c) Business continuity
 - d) ISO compliance

3. NIST Cybersecurity Framework focuses on:
 - a) Identify, Protect, Detect, Respond, Recover ✓✓
 - b) Risk, Audit, Compliance
 - c) BCP only
 - d) Asset management
4. ITIL focuses on:
 - a) IT service management ✓
 - b) Cybersecurity
 - c) Risk management
 - d) Business continuity
5. Governance in GRC ensures:
 - a) Alignment of IT with business objectives ✓✓
 - b) Risk elimination only
 - c) Only compliance
 - d) Only audits
6. Internal audit aims to:
 - a) Evaluate internal controls and compliance ✓✓
 - b) Eliminate all risks
 - c) Only assess IT assets
 - d) Only document policies
7. External audit is conducted by:
 - a) Independent auditors ✓
 - b) Internal staff
 - c) IT department
 - d) Risk officers
8. Key audit principles include:
 - a) Independence, objectivity, evidence-based ✓✓
 - b) Subjectivity, discretion, opinion-based
 - c) Risk avoidance
 - d) Only compliance checking
9. Control objectives in COBIT are linked to:
 - a) Business goals and IT processes ✓
 - b) Audit only
 - c) Risk avoidance only
 - d) BCM only
10. Compliance audits assess:
 - a) Adherence to laws, regulations, standards ✓✓
 - b) Only IT processes
 - c) Only residual risks
 - d) Only BCP plans
11. Governance frameworks help organizations:
 - a) Ensure accountability, transparency, and value delivery ✓✓
 - b) Avoid risks only
 - c) Implement IT only
 - d) Only comply with ISO 27001

12. Key NIST CSF categories include:

- a) Identify, Protect, Detect, Respond, Recover ✓
- b) Plan, Do, Check, Act
- c) Risk, Audit, Control
- d) BCM, RTO, RPO

13. ITIL processes include:

- a) Incident, Problem, Change, Service Level Management ✓
- b) Risk, Residual, ALE
- c) RTO, RPO, BIA
- d) Security audit only

14. An internal auditor reports to:

- a) Highest level of management or audit committee ✓
- b) IT manager
- c) Risk officer
- d) External auditor

15. Key COBIT principles include:

- a) Meeting stakeholder needs, covering the enterprise, applying a holistic approach ✓
- b) Only IT operations
- c) Only audit compliance
- d) Only BCM

16. Segregation of duties is critical to:

- a) Prevent fraud and errors ✓
- b) Increase asset value
- c) Reduce downtime
- d) Improve RTO

17. Audit evidence must be:

- a) Sufficient, reliable, relevant ✓
- b) Only documented
- c) Only oral statements
- d) Only quantitative

18. Corrective actions post-audit ensure:

- a) Issues are addressed and risks reduced ✓
- b) Audit closure only
- c) Documentation only
- d) Only management review

19. Risk-based auditing focuses on:

- a) High-impact and high-likelihood risks ✓
- b) All assets equally
- c) Only IT systems
- d) Only BCM

20. Key NIST Identify function includes:

- a) Asset management, governance, risk assessment ✓
- b) Only incident response
- c) Only recovery

- d) Only compliance
- 21. ITIL Change Management ensures:
 - a) Changes are evaluated, approved, and implemented with minimal disruption ✓
 - b) All risks are avoided
 - c) Only IT audits
 - d) Only BCM
- 22. COBIT process domains include:
 - a) Governance and Management ✓
 - b) Risk only
 - c) ITIL only
 - d) ISO 27001 only
- 23. IT governance ensures:
 - a) Strategic alignment, value delivery, risk management, resource management ✓
 - b) Only compliance
 - c) Only audit success
 - d) Only IT operations
- 24. ISO 19011 provides guidance on:
 - a) Audit management ✓
 - b) Risk assessment
 - c) BCM
 - d) Security controls
- 25. Independence in auditing means:
 - a) Auditor is free from bias and conflict of interest ✓
 - b) Auditor works alone
 - c) Auditor avoids IT staff
 - d) Auditor reports only to IT
- 26. Compliance frameworks often integrated with GRC include:
 - a) ISO 27001, PCI-DSS, GDPR ✓
 - b) Only BCM
 - c) Only ITIL
 - d) Only COBIT
- 27. Key IT audit types include:
 - a) Operational, compliance, financial, forensic ✓
 - b) Only IT security
 - c) Only BCM
 - d) Only internal
- 28. Audit scope defines:
 - a) Areas, processes, and controls to be examined ✓
 - b) Only risks
 - c) Only residual risks
 - d) Only IT assets
- 29. Audit findings must be:
 - a) Documented, communicated, and followed up ✓
 - b) Only verbally reported
 - c) Ignored

- d) Only for IT
- 30. Continuous monitoring in GRC ensures:
 - a) Risks and controls are consistently evaluated ✓
 - b) Only during audit
 - c) Only during incident
 - d) Only at RTO

Batch 5: Cybersecurity Metrics & Miscellaneous – 40 Questions

1. KPI stands for:
 - a) Key Performance Indicator ✓
 - b) Knowledge Process Index
 - c) Key Policy Implementation
 - d) Known Protection Index
2. A key cybersecurity KPI could be:
 - a) Number of incidents detected ✓
 - b) Asset inventory only
 - c) RTO only
 - d) Policy documentation only
3. Mean Time to Detect (MTTD) measures:
 - a) Average time to detect a security incident ✓
 - b) Average downtime
 - c) Average risk
 - d) Average RTO
4. Mean Time to Respond (MTTR) measures:
 - a) Average time to contain and resolve an incident ✓
 - b) Average downtime
 - c) Asset recovery
 - d) Policy update time
5. GDPR focuses on:
 - a) Data protection and privacy ✓
 - b) IT operations
 - c) Audit compliance only
 - d) BCM only
6. PII stands for:
 - a) Personally Identifiable Information ✓
 - b) Privacy Impact Index
 - c) Policy Implementation Information
 - d) Processed Information Inventory
7. Security metrics should be:
 - a) Measurable, relevant, and actionable ✓
 - b) Only quantitative
 - c) Only qualitative
 - d) Optional
8. Control effectiveness formula is:

- a) $\% \text{ risk reduction} = (\text{Inherent} - \text{Residual}) \div \text{Inherent} \times 100$ ✓
 - b) $\text{ALE} \times \text{ARO}$
 - c) $\text{Risk} \times \text{Likelihood}$
 - d) $\text{RTO} \times \text{RPO}$
9. Cybersecurity compliance ensures:
- a) Adherence to laws, regulations, and standards ✓
 - b) Only risk elimination
 - c) Only audit preparation
 - d) Only BCM
10. Security incidents should be classified by:
- a) Impact and likelihood ✓
 - b) Asset value only
 - c) Policy only
 - d) Control effectiveness
11. Security metrics examples include:
- a) Incidents per month, patching rate, audit findings ✓
 - b) RTO only
 - c) Risk acceptance only
 - d) Policies only
12. Data breach notification is required under:
- a) GDPR ✓
 - b) ISO 27001 only
 - c) ISO 22301 only
 - d) COBIT only
13. Phishing attack success rate is an example of:
- a) Security metric ✓
 - b) Risk treatment
 - c) Residual risk
 - d) RTO
14. Percentage of systems patched within SLA is:
- a) Security KPI ✓
 - b) Risk appetite
 - c) Residual risk
 - d) RPO
15. Security awareness training completion rate is:
- a) KPI ✓
 - b) ALE
 - c) SLE
 - d) Residual risk
16. Privacy by design is:
- a) Integrating privacy into system development ✓
 - b) Only for GDPR
 - c) Only for IT
 - d) Only for audit
17. Risk exposure formula is:

- a) $\text{Exposure} = \text{Probability} \times \text{Impact}$ ✓
 - b) $\text{Exposure} = \text{SLE} \times \text{ARO}$
 - c) $\text{Exposure} = \text{RTO} \times \text{RPO}$
 - d) $\text{Exposure} = \text{Control} \times \text{Residual}$
18. Security control effectiveness can be improved by:
- a) Testing, monitoring, and updates ✓
 - b) Ignoring low-risk assets
 - c) Documentation only
 - d) Annual audit only
19. Vulnerability scanning frequency should be:
- a) Regularly and after significant changes ✓
 - b) One-time
 - c) Only when incidents occur
 - d) Optional
20. Penetration testing primarily evaluates:
- a) System weaknesses and exploitability ✓
 - b) Audit documentation
 - c) Asset classification
 - d) RTO
21. A residual risk of 20% means:
- a) 20% of inherent risk remains after controls ✓
 - b) 20% of ALE
 - c) 20% downtime
 - d) 20% RPO
22. Key elements of GRC include:
- a) Governance, Risk management, Compliance ✓
 - b) BCP only
 - c) IT audit only
 - d) KPI only
23. Security policy must be:
- a) Approved by management, communicated, and reviewed ✓
 - b) Written by IT only
 - c) Optional
 - d) Only for audit
24. Compliance monitoring ensures:
- a) Controls and policies are implemented and effective ✓
 - b) Only documented
 - c) Only reported
 - d) Only IT systems
25. Cloud security metrics include:
- a) SLA compliance, incidents, misconfigurations ✓
 - b) RTO only
 - c) ALE only
 - d) Only audit logs
26. Data retention compliance requires:

- a) Following legal and business requirements ✓
 - b) Keeping all data indefinitely
 - c) Deleting data randomly
 - d) Ignoring policies
27. Security incidents post-mortem helps to:
- a) Identify root causes and improve controls ✓
 - b) Document ALE only
 - c) Reduce RTO
 - d) Only satisfy auditors
28. Number of failed login attempts is an example of:
- a) Security metric ✓
 - b) KPI only
 - c) ALE
 - d) RPO
29. Privacy Impact Assessment (PIA) is conducted to:
- a) Assess risks to personal data ✓
 - b) Only for ISO 27001
 - c) Only for audits
 - d) Only for BCP
30. Incident response metrics include:
- a) MTTD, MTTR, incidents closed ✓
 - b) RTO only
 - c) RPO only
 - d) ALE only
31. Percentage of critical vulnerabilities remediated within SLA measures:
- a) Security KPI ✓
 - b) Risk appetite
 - c) Residual risk
 - d) RPO
32. User access review completion rate is:
- a) KPI ✓
 - b) ALE
 - c) SLE
 - d) RTO
33. Threat intelligence helps to:
- a) Identify emerging risks and attacks ✓
 - b) Reduce RPO only
 - c) Document policies only
 - d) Audit only
34. Risk formula using ALE:
- a) $ALE = SLE \times ARO$ ✓
 - b) $ALE = RTO \times RPO$
 - c) $ALE = \text{Residual Risk} \times \text{Control}$
 - d) $ALE = \text{Exposure Factor} \times RTO$
35. KPI dashboards help management:

- a) Make informed decisions and track security posture ✓
- b) Only audit
- c) Only document controls
- d) Only implement ISO

36. Residual risk calculation is:

- a) Inherent risk – control effectiveness ✓
- b) $ALE \times ARO$
- c) Likelihood $\times$ Impact
- d) RTO – RPO

37. GDPR compliance requires:

- a) Lawful data processing, consent, breach notification ✓
- b) Only IT controls
- c) Only audits
- d) Only BCP

38. Key cybersecurity principle: Confidentiality means:

- a) Protecting information from unauthorized access ✓
- b) Ensuring uptime
- c) Risk elimination
- d) RPO compliance

39. Integrity in cybersecurity ensures:

- a) Information is accurate and unaltered ✓
- b) Only availability
- c) Only audit compliance
- d) Only risk reduction

40. Availability in cybersecurity ensures:

- a) Authorized users can access information when needed ✓
- b) Data is confidential
- c) Integrity only
- d) Risk appetite